

SAT 3812: Cyber Security I

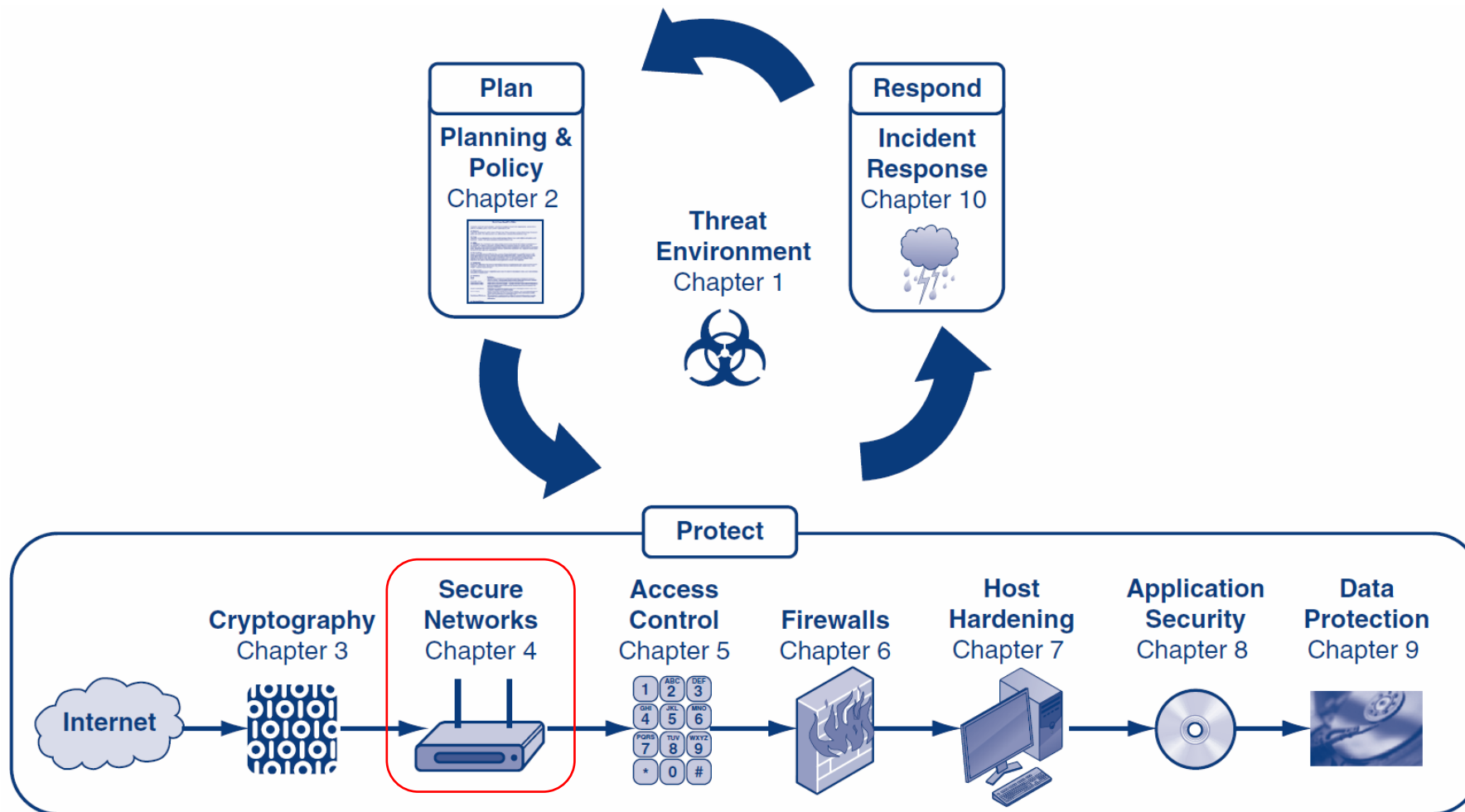
Network Security and Patch
Management

Instructor: Yunlong Xing



Learning Objectives

- Explain how ARP poisoning works.
- Understand common wifi security protocols including WEP, WPA, and WPA2.
- Describe potential attacks against wireless networks.
- Explain how to secure and harden networks and hosts.
- Explain Zero-day vulnerabilities, CVE, patch management, and endpoint protection.
- Explain common security concepts including IoT, Honeypot, honeynet, VoIP security, IPSec, BYOD, PAN, IPSec, VPN, and covert channel.



4.1: Threats to Secure Networks

- Modern Networks have many vulnerabilities
 - The *means* of delivering the messages could be stopped, slowed, or altered
 - The *route* the messages took could be altered
 - Messages could be *redirected* to false recipients
 - Attackers could gain *access* to communication channels that were previously considered closed and confidential

4.1: Death of the Perimeter

- The “castle” model
 - Good guys on the inside, attackers on the outside, and a well-guarded point of entry
- Death of the Perimeter
 - It is impractical, if not impossible, to force all information in an organization through a single point in the network
 - New means of attacking networks (e.g., smart phones) are constantly emerging
 - Line between “good guys” and “bad guys” has become blurred

4.1: Death of the Perimeter

■ The “city” model

- No distinct perimeter, and there are multiple ways of entering the network
- Like a real city, who you are will determine which buildings you will be able to access
- Greater need for:
 - Internal intrusion detection
 - Virtual LANs
 - Central authentication servers
 - Encrypted internal traffic

What's Next?

4.1 Introduction

4.2 Denial-of-Service (DoS) Attacks

4.3 ARP Poisoning

4.4 Access Control for Networks

4.5 Ethernet Security

4.6 Wireless Security

4.3: ARP Poisoning

■ Address Resolution Protocol (ARP)

- Used to resolve 32-bit IP addresses (e.g., 55.91.56.21) into 48-bit local MAC addresses (e.g., 01-1C-23-0E-1D-41)
 - Physical address or MAC address
- ARP tables store resolved addresses (below)

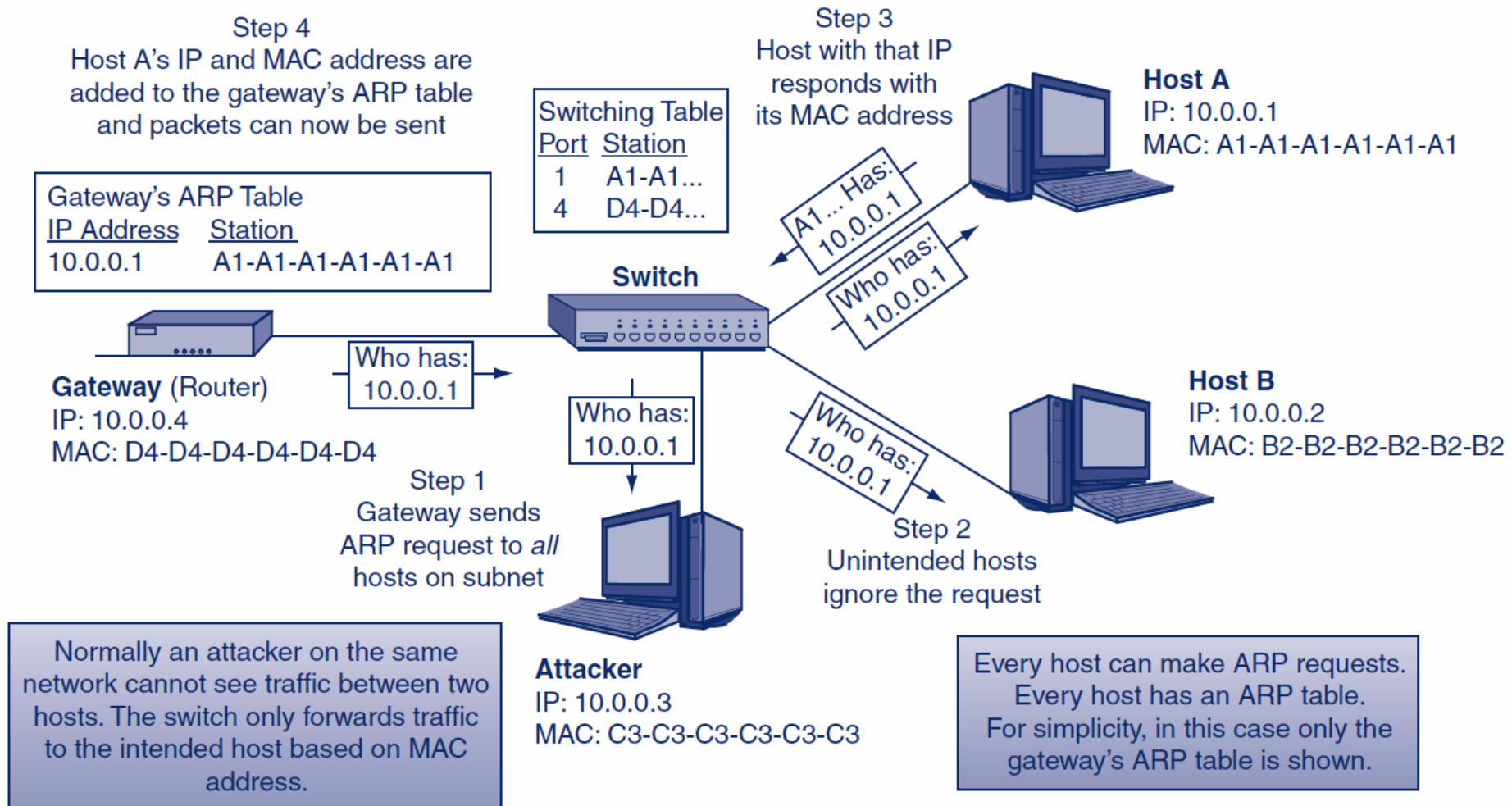
Internet Address	Physical Address	Type
55.91.74.11	f8-66-f2-75-58-7f	dynamic
55.91.74.12	00-24-e8-c4-df-b1	dynamic
55.91.74.13	00-22-19-03-1a-ff	dynamic
55.91.74.14	00-15-c5-41-d9-04	dynamic
55.91.74.15	5c-26-0a-0f-7d-c9	dynamic

4.3: ARP Poisoning

■ ARP Poisoning

- Network attack that manipulates host ARP tables to reroute local-area network (LAN) traffic
- Possible man-in-the-middle attack
- Requires an attacker to have a computer on the local network
- An attack on both the *functionality* and *confidentiality* of a network

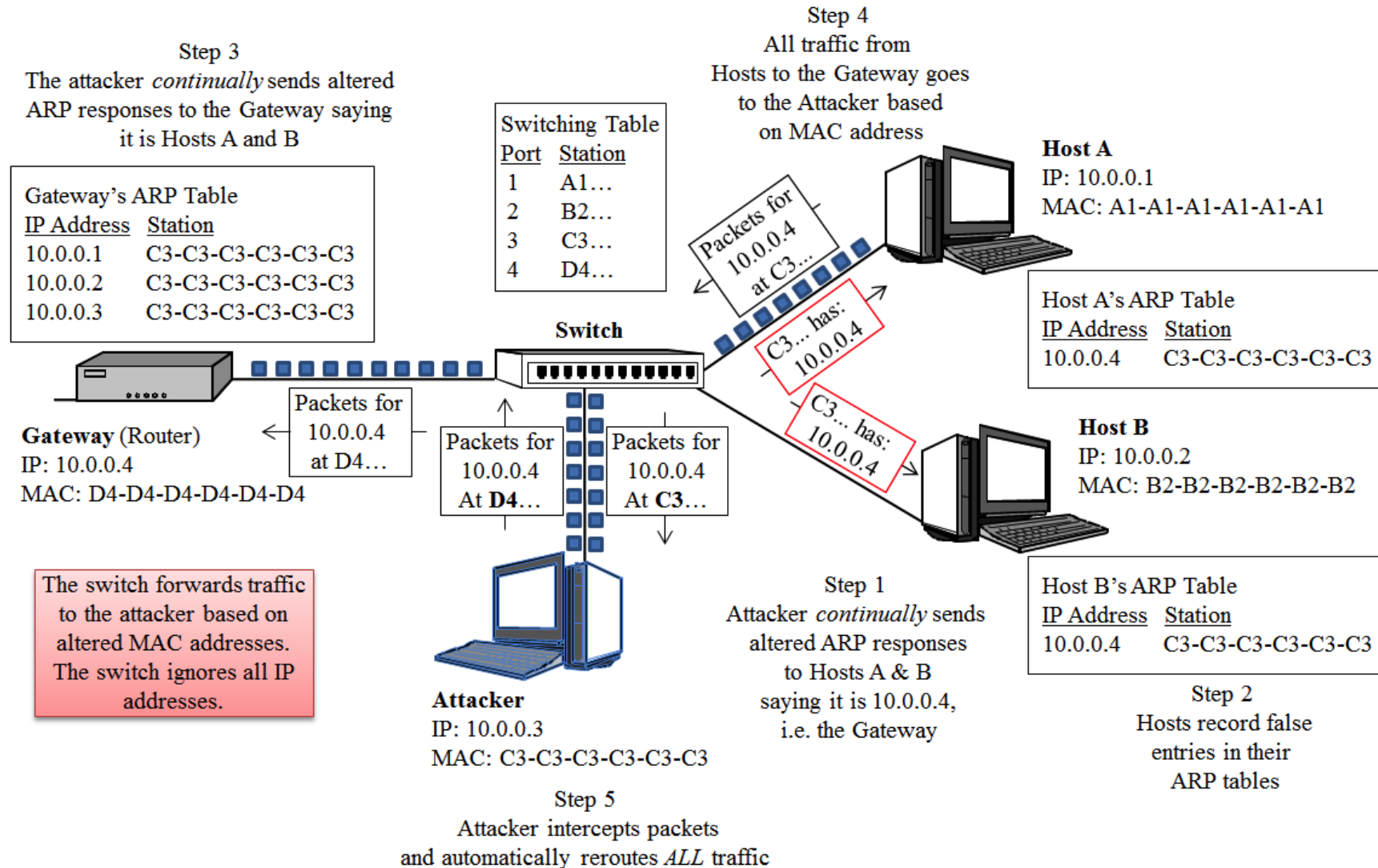
4.3: Normal ARP Operation



4.3: ARP Poisoning

- The problem: ARP requests and replies do NOT require authentication or verification
 - All hosts trust all ARP replies
 - ARP spoofing uses false ARP replies to map any IP address to any MAC address
 - An attacker can manipulate ARP tables on all LAN hosts
 - The attacker must send a continuous stream of unsolicited ARP replies

4.3: ARP Poisoning



4.3: ARP Poisoning

- Preventing ARP Poisoning
 - Static ARP tables are manually set
 - Not practical in large networks
 - Limit Local Access
 - Foreign hosts must be kept off the LAN
 - Physical access control and monitoring system

What's Next?

4.1 Introduction

4.2 Denial-of-Service (DoS) Attacks

4.3 ARP Poisoning

4.4 Access Control for Networks

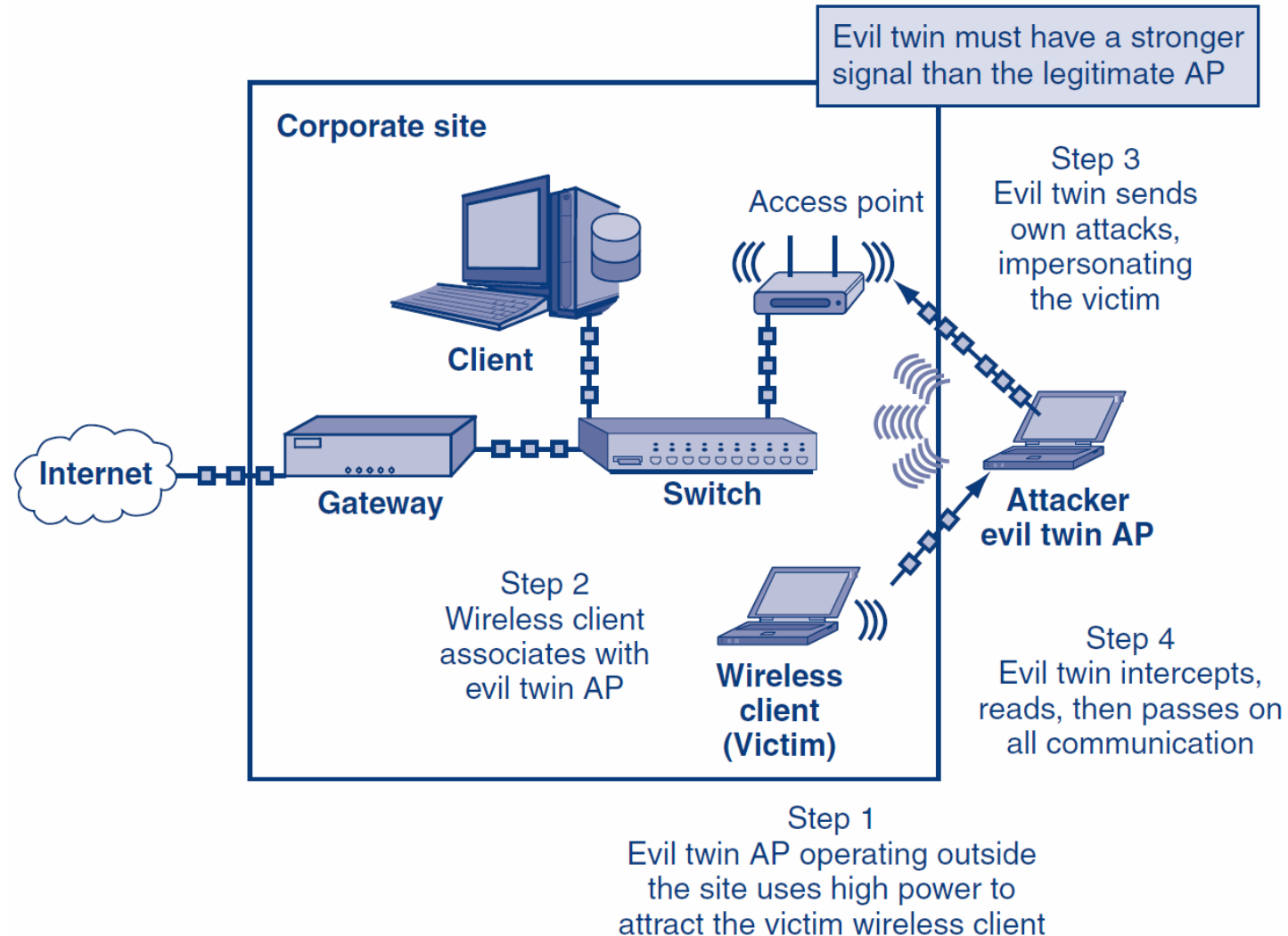
4.5 Ethernet Security

4.6 Wireless Security

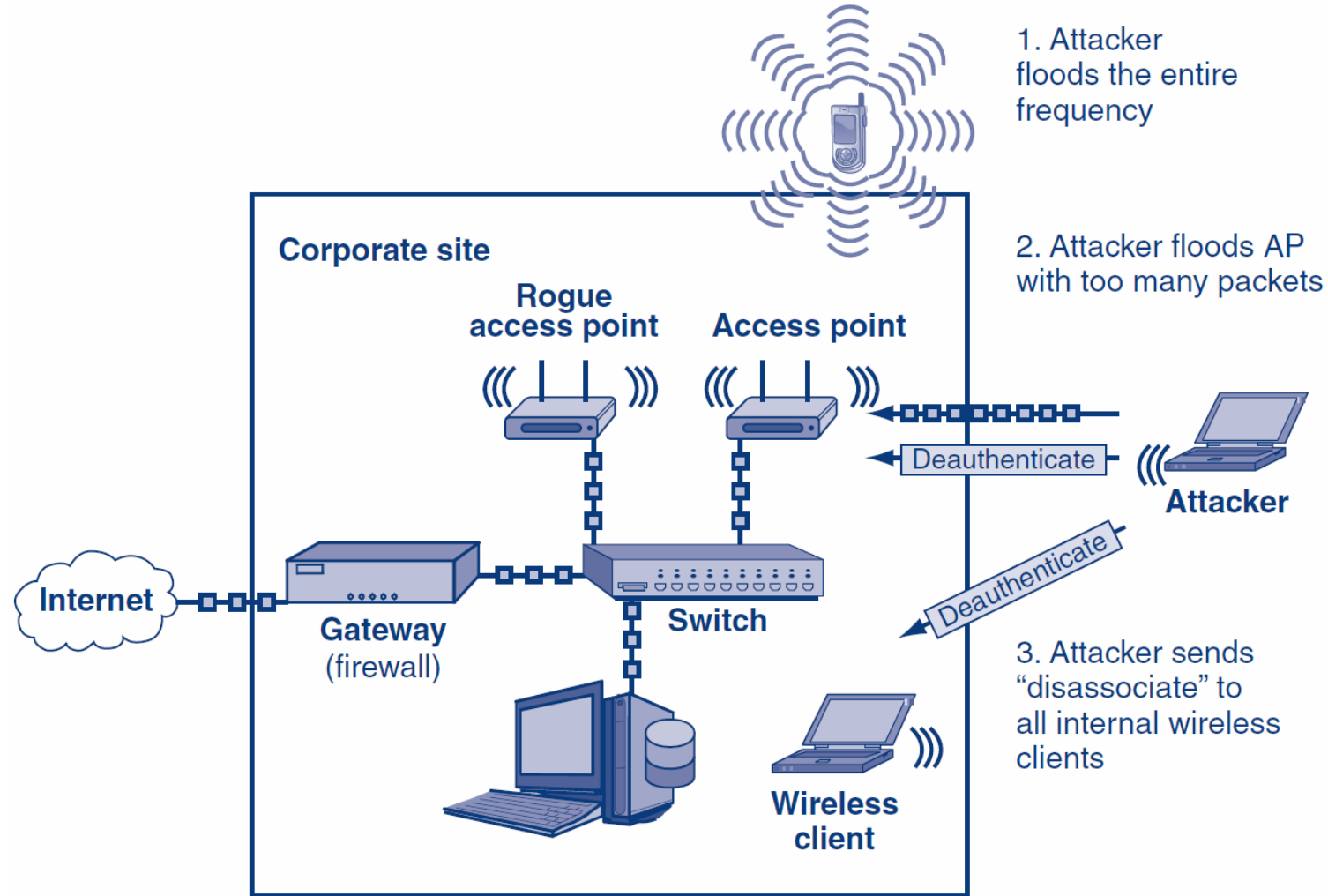
4.6: Unauthorized Network Access

- *Open networks* can be legally accessed by anyone
 - Found in public places like cafés, coffee shops, universities, etc.
- *Private networks* that do not allow access unless specifically authorized
- *Secured networks* have security protocols enabled
 - Users are authenticated and wireless traffic is encrypted

4.6: Evil Twin Access Point



4.6: Wireless DoS – Disassociation & Jamming



Other Wireless Attacks

- Use aircrack-ng suite to crack WEP/WPA password
- Create a fake Starbucks wifi AP with Wifi PineApple.
- Hack garage door with a wireless signal capture and replay
- Hack neighborhood wifi like a road warrior
- **DO NOT HACK!**

4.6: Wired Equivalent Privacy (WEP)

- **Origin of WEP**

- Original core security standard 802.11, created in 1997

- **Uses a Shared Key**

- Each station using the access point uses the same (shared) key
- The key is supposed to be secret, so knowing it “authenticates” the user

4.6: Wired Equivalent Privacy (WEP)

■ Problem with Shared Keys

- Shared keys should be changed frequently
 - WEP had no way to do automatic rekeying
 - Because “everybody knows” the key, employees often give it out to strangers
- Faulty design in key encryption

■ Conclusion:

- Corporations should never use WEP for security

4.6: Wi-Fi Protected Access (WPA)

- WPA

- WPA extends the security of RC4 primarily by increasing the IV from 24 bits to 48 bits
- Stronger but not enough

- WPA2 (802.11i)

- 802.11 Working Group completed the 802.11i standard (WPA2) in 2002
- Uses stronger security methods

4.6: False 802.11 Security

■ **Turning Off SSID Broadcasting**

- Service set identifier (SSID) is an identifier for an access point
 - Users must know the SSID to use the access point
 - Access points frequently broadcast their SSIDs
- Some writers favor turning off of this broadcasting
- Will not deter the attacker
 - Transmitted in the clear in each transmitted frame

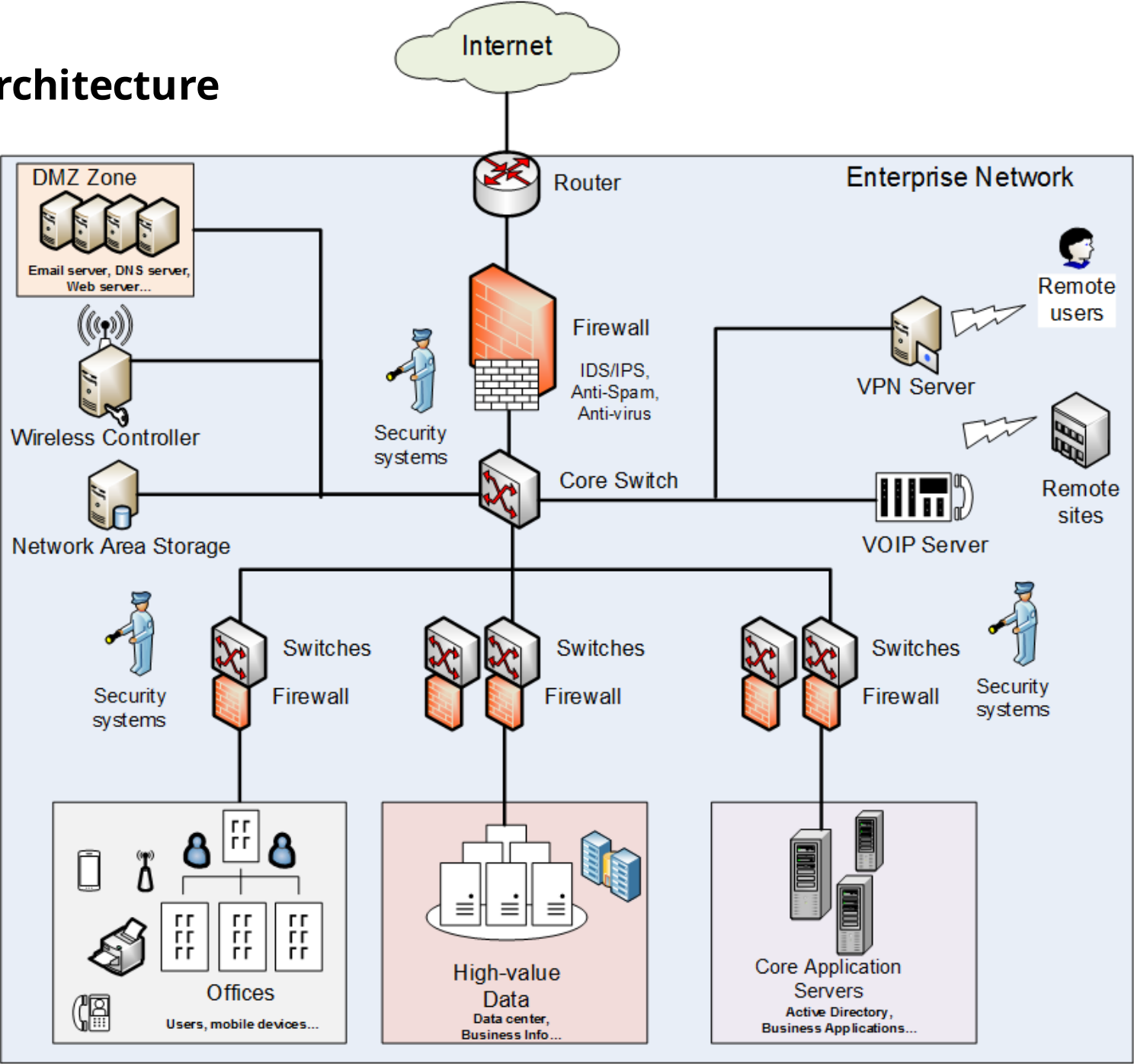
4.6: False 802.11 Security

■ **MAC Access Control Lists**

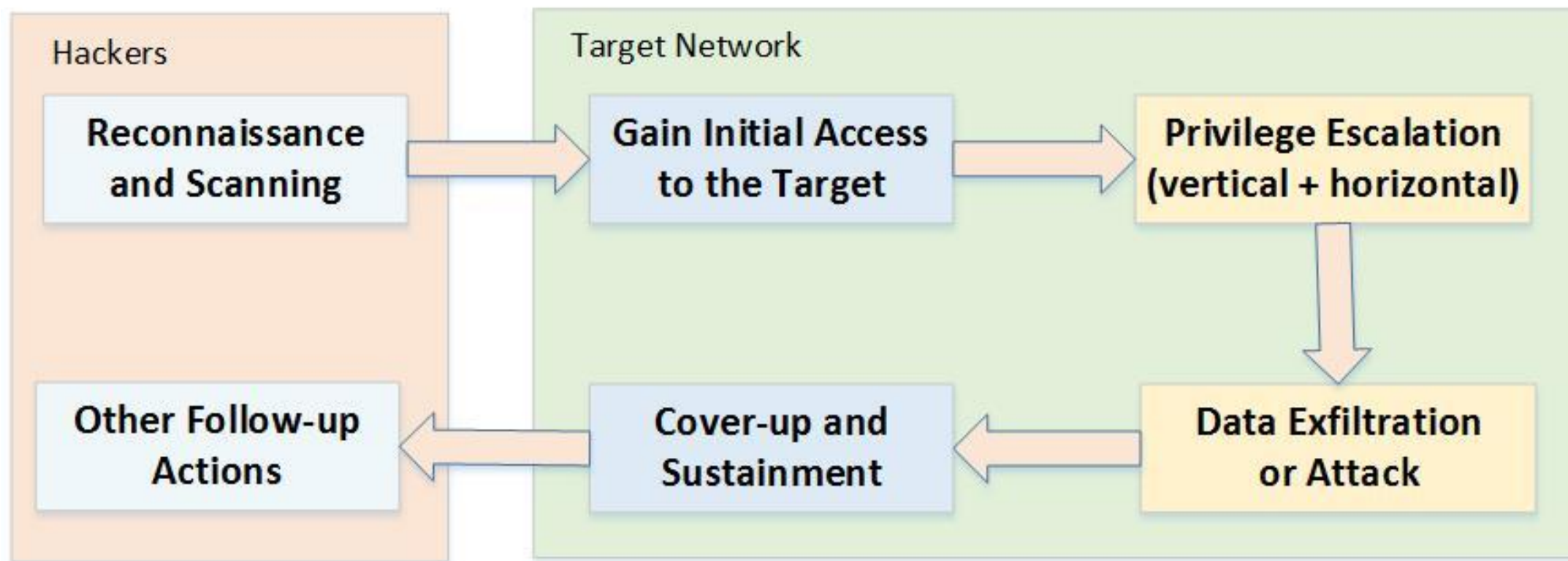
- Access points can be configured with MAC access control lists
 - Only permit access by stations with NICs having MAC addresses on the list
 - However, MAC addresses are sent in the clear in frames, so attackers can learn them
 - Attacker can then spoof one of these addresses
- Why some networks still require MAC address registration?

Other Topics in Network Security

Enterprise Network Architecture

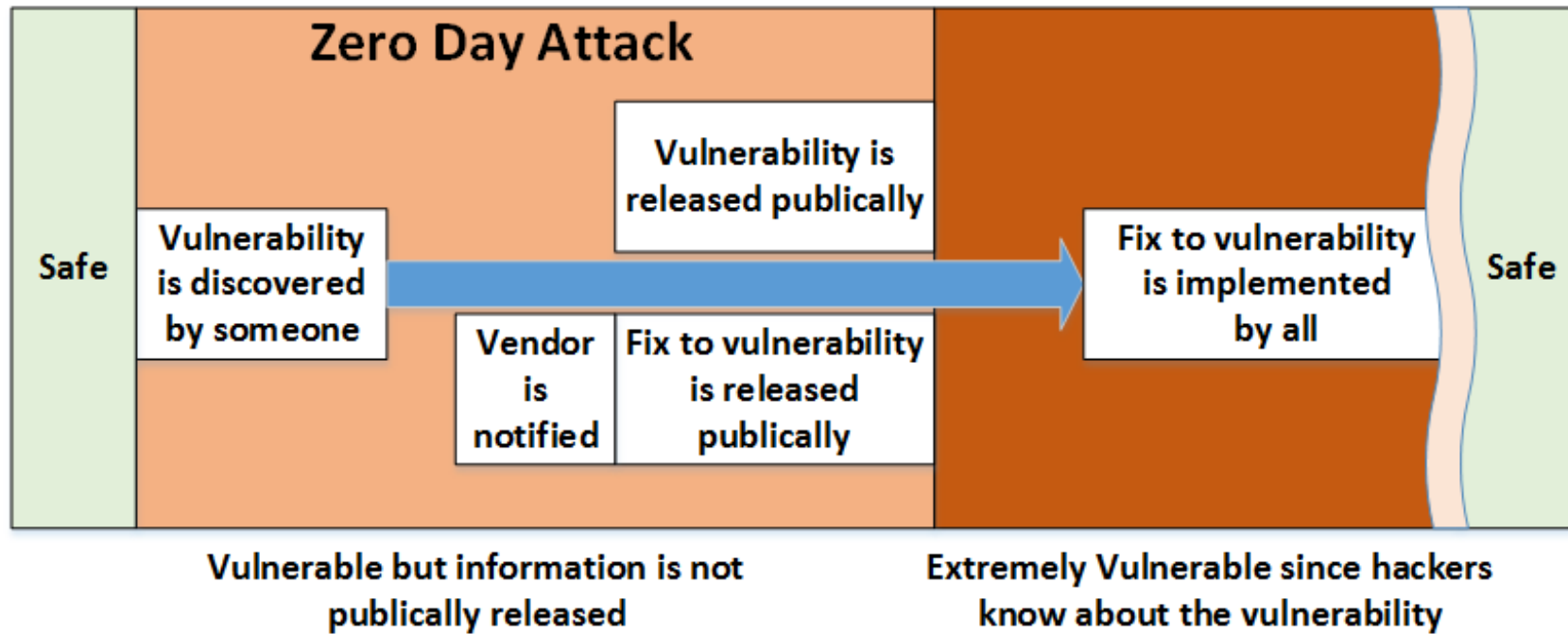


Typical Steps in Cyber Attacks



Zero-Day Vulnerability

Patch your system, or hackers will do it for you.



Alert Websites

- CVE: Common Vulnerabilities and Exposures
- exploit-db.com
 - you will find tons of security vulnerabilities...And hackers can find them too.
 - Many entries have attacking code with it!
- cve.mitre.org
 - Details of CVEs
- US-CERT
 - <https://www.us-cert.gov/ncas/alerts>

Common Security Vulnerabilities

- Most Data Breaches Are Caused By...
 - Missing Patches / Updates
 - Patching and updating
 - Misconfigurations of Systems / Not Hardened
 - Host hardening
 - Not Applying Principle of Least Privilege
 - Apply least access
 - End user activity
 - Educate users
- Security vs Convenience

Patch Management

- Patch management is an area of systems management that involves acquiring, testing, and installing multiple patches (code changes) to an administered computer system.
 - Automatic management
 - Manual management



IoT

- IoT: Internet of Things
- IoT involves adding internet connectivity to a system of interrelated computing devices, mechanical and digital machines, objects, animals and/or people.
- Each "thing" is provided a unique identifier and the ability to automatically transfer data over a network.
- Examples: smart web cameras, smart thermo controls, smart door locks...

IoT Security

- IoT security has become the subject of scrutiny after a number of high-profile incidents where a common IoT device was used to infiltrate and attack the larger network.
- Challenges
 - Default or hard-coded passwords
 - Hard to update firmware or software
 - Inexperienced users
 - Unprepared professionals and businesses

SCADA

- Industrial Control Systems (ICS)
- Supervisory control and data acquisition (SCADA) is a industrial control system architecture that uses computers, networked data communications and graphical user interfaces for high-level process supervisory management, but uses other peripheral devices such as programmable logic controller (PLC) and discrete PID controllers to interface with the process plant or machinery.
- Cyber-physical infrastructure; critical infrastructure

ICS Security

- ICS and SCADA Security is a big concern
- Most ICS systems are not ready for cyber attacks.
- Examples:
 - Power grid outage in Ukraine due to cyber attacks in 2015

Honeypots

■ Honeypot

- A fake server or entire network segment with multiple clients and servers
- Legitimate users should never try to reach resources on the honeypot
- Primarily used by researchers studying attacker behavior by recording everything a visitor does

Honeynet

- A honeynet is a network set up with intentional vulnerabilities
- Its purpose is to invite attack, so that an attacker's activities and methods can be studied and that information used to increase network security.
- A honeynet contains one or more honey pots

Bring your own device (BYOD)

- The policy of permitting employees to bring personally owned devices (laptops, tablets, and smart phones) to their workplace, and to use those devices to access privileged company information and applications.
- The phenomenon is commonly referred to as IT consumerization.
 - BYOD is making significant inroads in the business world, with about 75% of employees in high growth markets such as Brazil and Russia and 44% in developed markets already using their own technology at work

Hardening

- Hardening is to providing various means of protection in a computer system. Protection is provided in various layers and is often referred to as defense in depth.
 - Host hardening and network hardening
- Hardening activities can include:
 - Keeping security patches and hot fixes updated
 - Monitoring security bulletins and news
 - Closing certain ports such as server ports
 - Not allowing file sharing among programs

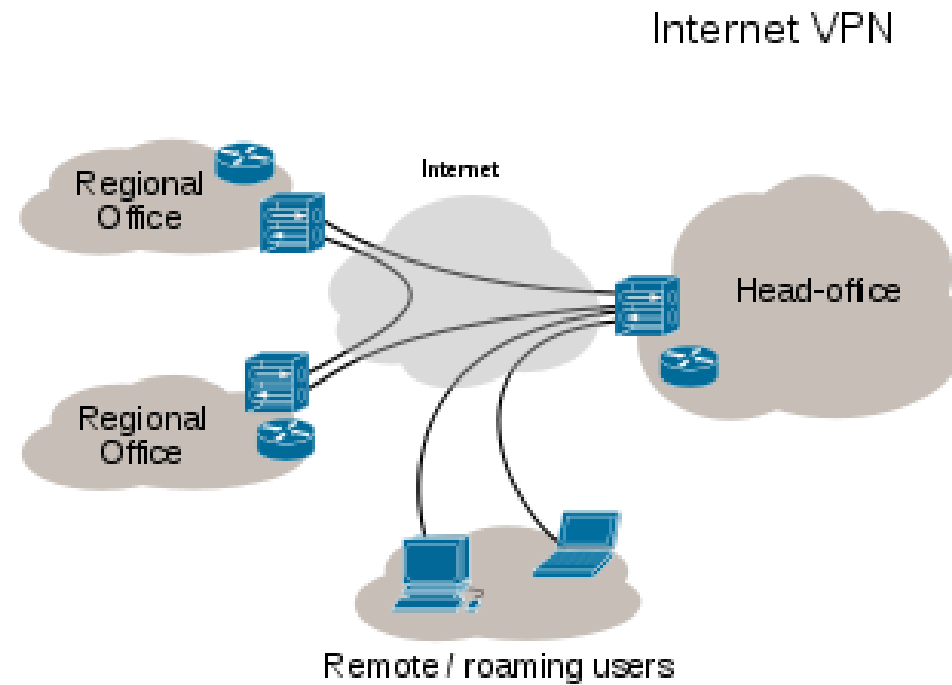
Host/Network Hardening

- Hardening can include:
 - Installing virus and spyware protection
 - Keeping a backup
 - Creating strong passwords
 - Never opening emails or attachments from unknown senders
 - Removing unnecessary programs and user accounts from the computer
 - Using encryption where possible
 - Hardening security policies

VPN

- A virtual private network (VPN) extends a private network across a public network, and enables users to send and receive data across shared or public networks as if their computing devices were directly connected to the private network.
- Information traveling between a connected device (computer, smartphone, tablet) and a VPN server is encrypted, and as a result, any applications running on the VPN network benefit from the security, functionality, and strength of the private network.

VPN



Example: vpn.mtu.edu

Side Channel Attack

- A side-channel attack is any attack based on the **physical implementation** of a system (as opposed to attacks which are based on an algorithm) which is performed via channels or mediums that are created as a **side effect** of the main operation of the attacked system.

Side Channel Attack Examples

- Acoustic analysis
 - [Sounds of keys clicking can be analyzed and typed phrases and passwords can be recovered](#)
 - [Ultrasound directed at an accelerometer to alter readings or attack Siri directly](#)
 - [Dolphin Attack](#)
- Timing attack
 - [Analyzes the time a system spends executing cryptographic algorithms.](#)
- Electromagnetic (EM) or Power Analysis attack
 - [Directly observes the power and electromagnetic \(EM\) variations of a cryptographic system during operations.](#)
 - [Measures and performs a signal analysis on the electromagnetic radiation emitted from a device.](#)

Covert/Side Channel Example

- Alice has **TOP SECRET** clearance, Bob has **CONFIDENTIAL** clearance
- Suppose the file space shared by all users
- Alice creates file FileXYZW to signal “1” to Bob, and removes file to signal “0”
- Once each minute Bob lists the files
 - If file FileXYZW does not exist, Alice sent 0
 - If file FileXYZW exists, Alice sent 1
- Alice can leak **TOP SECRET** info to Bob!

Covert Channel Example

Alice: Create file Delete file Create file Delete file

Bob: Check file Check file Check file Check file Check file

Data: 1 0 1 1 0



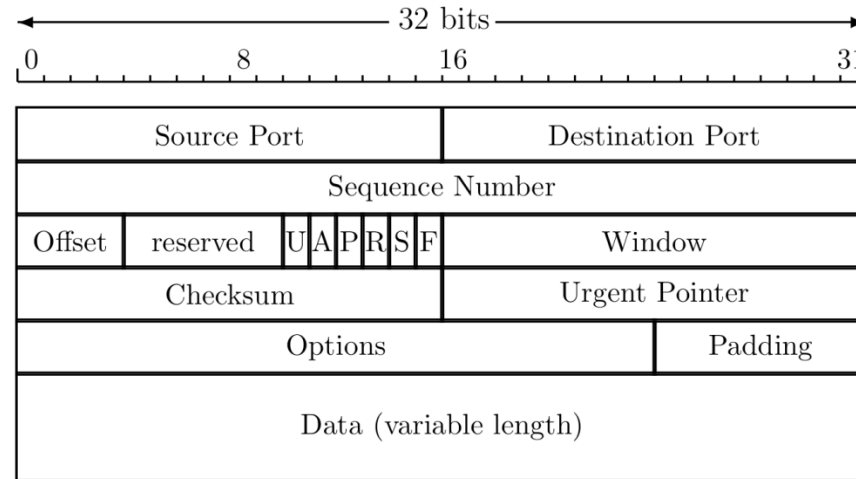
Covert Channel

- Other examples of covert channels
 - Print queue
 - ACK messages
 - Network traffic, etc., etc., etc.
- When does a covert channel exist?
 1. Sender and receiver have a **shared resource**
 2. Sender able to vary property of resource that receiver can observe
 3. Communication between sender and receiver can be **synchronized**

Covert Channel

- Covert channels **exist almost everywhere**
- Easy to eliminate covert channels...
 - Provided you eliminate all shared resources and all communication
- **Virtually impossible** to eliminate all covert channels in any useful system
 - DoD guidelines: goal is to **reduce covert channel capacity** to no more than 1 bit/second
 - Implication is that DoD has given up trying to eliminate covert channels!

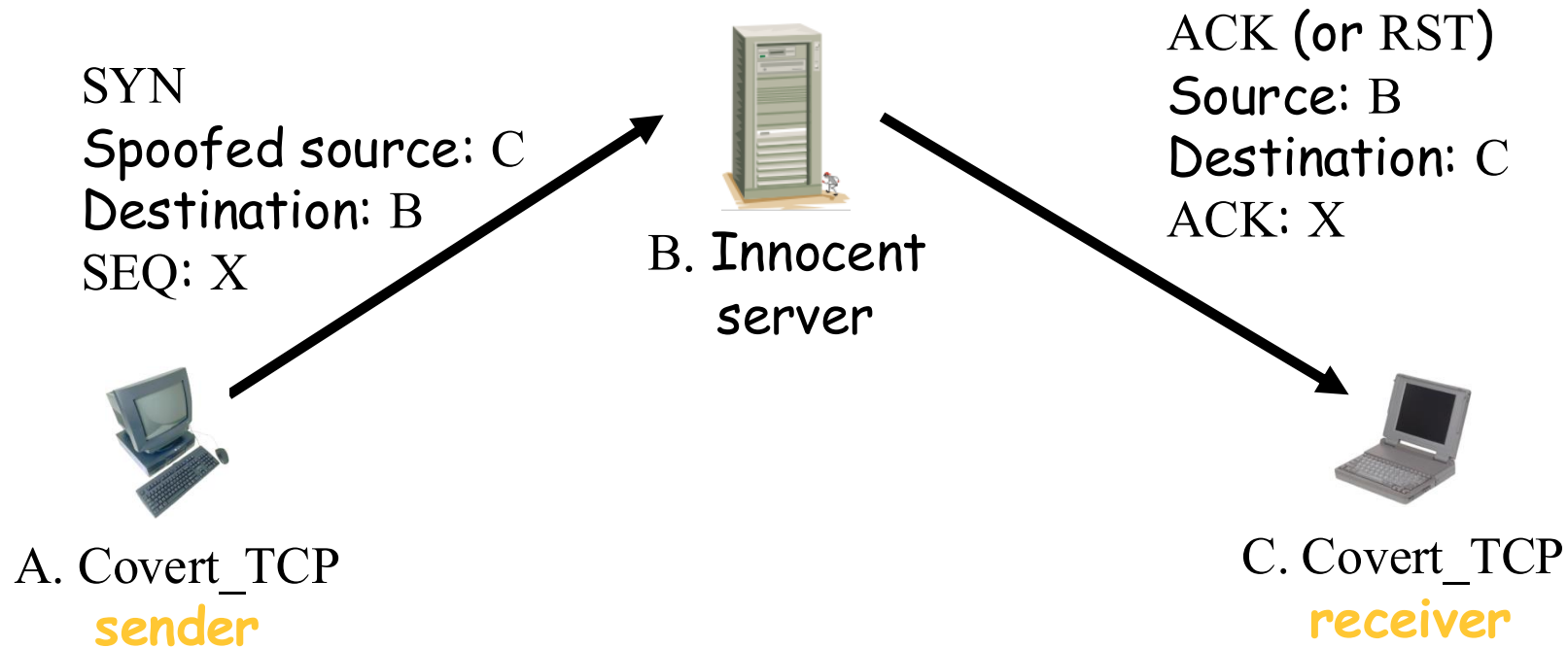
Real-World Covert Channel



- Hide data in TCP header “reserved” field
- Or use `covert_TCP`, tool to hide data in
 - Sequence number
 - ACK number

Real-World Covert Channel

- Hide data in TCP sequence numbers
- Tool: covert_TCP
- Sequence number X contains covert info



Question : Imagine a Bell and LaPadula-like secure system with the following five operations.

(READ r): if the subject and object exist and have the right relationship, the subject obtains the current value of the object; otherwise, do nothing.

(WRITE w): if the subject and object exist and have the right relationship, the object gets value v; otherwise, do nothing.

(CREATE c): add a new object with the given name, a level equal to the subject's level, and an initial value of 0. If an object of that name exists, do nothing.

(DESTROY d): eliminate the designated object from the state, assuming that the object exists and the subject has WRITE access to it. Otherwise, do nothing.

(LIST l): the subject lists the names of all objects on the system. If no access right, use * to replace object names.

Describe a covert channel in this system. That is, show a series of actions that will send a 0 from high to low, and another that will send a 1 from high to low.

Discussion

- You are a cybersecurity consultant working with a company that is deploying an AI model connected to a database.
- Where should you get started?
- What are the potential security implications?